EASYSHOP FRONTEND INTEGRATION — COMPLEMENTARY SPECIFICATION

Módulo de Recuperação de Palavra-Passe & Segurança (AT8910)

Projeto: EasyShop Backend API (AT8910)	**Escopo:** Auth & Password Recovery
Tecnologias: Node.js, Express, Prisma ORM, PostgreSQL	**Serviço SMTP:** Nodemailer + Mailtrap Sandbox
Base URL: http://localhost:3000/api	**Formato Pedidos:** application/json

1. Visão Geral do Fluxo de Recuperação

O módulo de **Recuperação e Reposição de Palavra-Passe** garante um processo seguro em duas etapas entre o frontend e a API backend [1]:

- **Etapa 1 — Solicitação de Recuperação:** O utilizador informa o e-mail no frontend. O backend gera um token seguro (crypto.randomBytes(32)), armazena o hash na DB e envia um e-mail com instruções via Nodemailer/Mailtrap Sandbox [1].
- **Etapa 2 — Reposição de Palavra-Passe:** O utilizador envia o token recebido e a nova palavra-passe. O backend valida o token, re-encripta a palavra-passe com bcrypt e elimina o token usado numa transação atómica [1, 2].

2. Configuração de Ambiente (`.env`)

A API necessita das seguintes variáveis SMTP configuradas no ficheiro .env para o envio de e-mails transacionais [2]:

Variável .env	Exemplo Mailtrap Sandbox	Descrição
SMTP_HOST	sandbox.smtp.mailtrap.io	Servidor SMTP para simulação de envios [2]
SMTP_PORT	2525	Porta de conexão SMTP [2]
SMTP_USER	<username_sandbox>	Utilizador de autenticação Mailtrap [2]
SMTP_PASS	<password_sandbox>	Palavra-passe de autenticação Mailtrap [2]

3. Especificação Detalhada dos Endpoints

A. Solicitar Recuperação de Palavra-Passe

Endpoint:	POST /api/auth/esquecer-palavra-passe
Headers:	Content-Type: application/json
Ação:	Gera token seguro na tabela TokenRecuperacao e envia e-mail com instruções [3].

```
Request Body:
{ "email": "anibalrosarioofice@gamil.com" }

Response (200 OK):
{ "message": "Se o e-mail estiver registado, receberá as instruções de recuperação em breve." }
```

■ ***Segurança Frontend:*** *A resposta de sucesso é genérica quer o e-mail exista ou não, evitando a enumeração de utilizadores no sistema [3].*

B. Repor Palavra-Passe

Endpoint:	POST /api/auth/repor-palavra-passe
Headers:	Content-Type: application/json
Ação:	Valida token, encripta nova palavra-passe com bcrypt e atualiza DB atomicamente [4].

```
Request Body:
{ "token": "aeac1ca51e778e1fff8f66fa2f6b212561830ddfdd1d25afb3a9ef20a3fda6ea", "novaPalavraPasse":
"Anibalzinho@12" }

Response (200 OK):
{ "message": "Palavra-passe alterada com sucesso." }
```

Cenário de Erro (400 Bad Request)	Causa no Backend	Tratamento no Frontend
Token Inválido ou Expirado	Hash não encontrado na tabela TokenRecuperacao ou expirado [5].	Exibir mensagem e sugerir novo pedido de recuperação.
Password Curta (< 6 caracteres)	novaPalavraPasse com menos de 6 caracteres [5].	Validar tamanho no formulário antes do envio.

4. Decisões Técnicas e Arquitetura de Segurança

A implementação do módulo de autenticação e recuperação adota os seguintes padrões de segurança [5, 6]:

- **Hashing Criptográfico de Tokens:** Os tokens (crypto.randomBytes(32)) são armazenados na DB exclusivamente como hash bcrypt, prevenindo exposição mesmo em caso de vazamento de dados [5].
- **Transações Atómicas (`prisma.$transaction`):** Na redefinição de password, a atualização do hash, a remoção do token e o registo de auditoria ocorrem numa transação atómica. Falhas em qualquer etapa provocam *rollback* total [6].
- **Compatibilidade Híbrida de Hashes (scrypt + bcrypt):** Suporte a passwords legadas geradas por *seeds* em scrypt e novas passwords em bcrypt, mantendo retrocompatibilidade total no login [6].

5. Matriz Completa de Endpoints (Módulo AT8910)

Endpoint	Método	Acesso	Ação Principal na Aplicação
/api/auth/registar	POST	Público	Registo de novos utilizadores com encriptação bcrypt
/api/auth/login	POST	Público	Autenticação com suporte a hashes legados e novos
/api/auth/esquecer-palavra-passe	POST	Público	Geração de token de recuperação e envio por e-mail
/api/auth/repor-palavra-passe	POST	Público	Validação de token e redefinição de password
/api/produtos	GET	Público	Listagem de produtos com filtros e paginação
/api/produtos/:slug	GET	Público	Detalhe do produto, stock textual e produtos relacionados